Feature: Booking email works by default

From build-plan: feature 25a

Size: light - one real piece of logic (which sender and key an email uses, with one fallback); the rest is removing the key from forms. **Status:** verified **Branch:** feature/25a-booking-email-works-by-default

Goal

Every business sends its booking emails (confirmation, move, cancellation, the "New booking" notices, text replies passed on by email) from day one, with nothing typed in: through the agency's one Resend key (`RESEND_API_KEY`), from `bookings@<its domain>` when that domain is set up in the agency's Resend, and otherwise from `bookings@booking-crm.com` in the business's name. The owner gets the notices and the replies. A handover becomes "what's your email?".

In scope

- **Who sends.** Every business email goes out with the agency key. A business's own saved Resend key is no longer used (its row stays in the database, unread).
- **Which address.** In order: 1. the business's own sender address when one is saved (IA a la Orden's `hola@ialaorden.com` , Face and Body's `bookings@...`), kept as a choice; 2. otherwise `bookings@<domain>` , the domain taken from the business's Website (`https://www.primopainters.ca/x` gives `primopainters.ca`), when public DNS shows Resend's signing record `resend._domainkey.<domain>` ; 3. otherwise `bookings@booking-crm.com` . Always shown in the business's name: `"Primo Painters" <bookings@...>` .
- **One fallback.** When Resend refuses an email from 1 or 2 because the domain is not verified (a 403 refusal), the same email is sent once more from `bookings@booking-crm.com` , so a half-set-up domain never loses a booking email. Logged as one line naming the business, never the addresses.
- **Who hears.** "New booking" notices go to the saved notification address, or, when none is saved, to the business owner's login email. Replies keep today's rules (customer's Reply goes to the booked person or the business).
- **Forms.** The dashboard's email card keeps the two addresses (sender optional, notification optional) and drops the Resend key field and its test send. The admin "Client setup" form drops its Resend key field. The card shows which sender is in use right now and why ("from your domain" or "from booking-crm.com until your domain is added").
- **Work emails** (one email per business, 12h): a person's work address must be at the business's own domain, as today; the domain now comes from rule 1 or 2 above. With neither, saving a work email is refused as today.

- **Development.** Outside production, the agency key is not used for booking emails: the would-be sender is logged and nothing is sent (seed customers have fake addresses). Login codes are unchanged.
- **Docs.** `.env.example` and `AGENTS.md` say the agency key now carries every business's booking emails, and that a domain is added in Resend (and its four records in Vercel) to send from it.

Out of scope

- Signup, packages, Stripe (item 25).
- Adding a domain to Resend through its API (item 25 names it as later).
- Deleting stored business keys or the key table (a later clean-up, once 25a has run live).
- Texts, WhatsApp, reminder by email (the channels feature).

Build loop

After Frank's yes on this plan, the one step runs straight through: build, tests, the build log, commit and push to the feature branch. The review comes once, at `/complete` (light). Stops only for the three reasons in `AGENTS.md`.

Build steps

- ☑ 1. Sender and key resolution in `backend/lib/email/` (one new function that returns the key, the from line and the notify address for a business, used by the confirmation, move, cancellation, notice and text-reply paths in place of `setup.apiKey`, `setup.senderEmail`, `setup.notifyEmail`); the one-time fallback in the send path; the owner's email as notify fallback; the work-email domain from the same rule; the card and admin form without the key; docs. **Done when:** backend tests pass, including new ones for: own sender kept; website domain with the signing record gives `bookings@<domain>`; without it `bookings@booking-crm.com`; a 403 refusal resends once from `booking-crm.com`; no notify address falls back to the owner's email; nothing is sent outside production. The frontend and backend builds pass, and the email card on http://localhost:3400 shows the sender in use with no key field.

Files / areas

- `backend/lib/email/`: `find-booking-email-context.ts`, `find-business-email-details.ts`, `send-booking-emails.ts`, `send-move-emails.ts`, `send-cancellation-emails.ts`, `send-email.ts` (or a wrapper beside it for the fallback), `find-email-sending-state.ts`, `save-email-sending.ts`, `check-email-sending-key.ts` (its route goes), `read-email-settings.ts`; a new resolver file, one export.

- `backend/lib/text/pass-on-reply.ts`, `backend/lib/settings/save-resource.ts`, `backend/lib/settings/find-people-settings.ts`, `backend/lib/admin/provision-client.ts`.
- `backend/routes/email-sending-routes.ts`, `backend/routes/admin-routes.ts`.
- `frontend/components/email-sending/email-sending-card.tsx`, `frontend/components/admin/client-setup-form.tsx`, their api-client files and words.
- `.env.example`, `AGENTS.md`.

Data / contracts

- No migration. `organization.senderEmail` and `notifyEmail` keep their meaning (both optional now); `organization.website` gives the domain.
- The signing-record check is a DNS TXT lookup of `resend._domainkey.<domain>`, remembered per domain for an hour inside the process; a lookup failure counts as "not set up" (falls to `booking-crm.com`).
- The sender address shown in the card comes from the same resolver as the email, so the card never says one thing and the email does another.

Testing

Backend Vitest beside the code (`*.test.ts`), the DNS lookup and Resend behind the existing seams so tests make no network calls. The full backend suite runs before the step is called done.

Notes for the AI

- One export per backend file; types end in `Type`.
- Never log addresses or keys; the fallback line names the business id only.
- The agency key's own reach is checked before release, not in code (below).

Open questions

- **Before release, in Resend (Frank, one look):** API Keys, the key Railway uses (`scheduleads-live-2026-10`): does its Domain column say "All domains"? If it is limited to `booking-crm.com`, a new "Sending access, all domains" key replaces it on Railway at release, or every client-domain email falls back to `booking-crm.com`.

Implementation walkthrough

The sender rule (backend/lib/email/). `resolve-business-sender.ts` is the one place that decides where a business's emails come from: its website's domain (`website-domain.ts` reads it from the business's Website, set only by the agency admin), and only once public DNS shows Resend's signing record there (`has-resend-signing-record.ts` , which needs an actual key after `p=` and keeps each answer for an hour). Then its saved sender if that address is at the same domain, else `bookings@` the domain. Otherwise `bookings@booking-crm.com` . Always in the business's name. The first review's F-531 changed this: the built version trusted any saved sender, so an owner could have sent as another client's domain through the agency's key.

The key. `read-agency-booking-key.ts` gives the agency's `RESEND_API_KEY` live and in tests (which fake Resend and set a fake key themselves), and none on the laptop, so the seed's made-up customers are never emailed. No business key is read any more; the old table stays in the database, unused, for a later clean-up.

The send path. `find-booking-email-context.ts` and `pass-on-reply.ts` take the sender from the resolver; a business without a time zone, or with nowhere for its notices (no saved notification address and no owner), sends nothing and logs it. `send-email.ts` gained `fallbackFrom` : when Resend refuses the business's own domain (403), the same email goes once more from booking-crm.com under its own idempotency key (`<key>/agency`). Login codes never carry a fallback.

Notices. `find-business-email-details.ts` now reads the business's first owner's login email, which stands in when no notification address is saved.

The card and the admin form. `save-email-sending.ts` saves the two addresses, both optional, and refuses a sender not at the website's own domain (`sender_not_own_domain` , shown under the field, Spanish in `spanish-messages.ts`). `find-email-sending-state.ts` answers what is in use now, from the same resolver, so the card and the email agree. The key field, its test email (`check-email-sending-key.ts`), its storage and its refusal codes are gone, from the card and from "Set up a client".

Work emails. `save-resource.ts` and `find-people-settings.ts` take the business's own domain from the same resolver, so a person's work email must be at the website's domain once it is in Resend.

Bug caught on the laptop. The seed's website, example.com, publishes an empty signing record (`v=DKIM1; p=`), which the first check counted as set up; it now needs a key.

Docs. AGENTS.md has a "Booking emails (25a)" paragraph; `.env.example` 's comment was updated in Frank's own uncommitted copy (F-533).

Carried. F-532 (P2, reopened): a domain verified in another Resend account publishes the same record, so the card could say "from your domain" while the emails fall back; every current client domain is in the agency's one account. P3s: F-533 to F-540 (log wording, DNS time limit, untested text-reply fallback, stale comments, unused Spanish strings, admin form sender at any domain, the guard resting on the website staying admin-only).

Findings

25a/F-531 [P1] closed - Any business owner can make the agency's one key send its booking emails from another client's domain or from booking-crm.com

File: backend/lib/email/resolve-business-sender.ts:36-38; packages/shared/zod-validation/organization-validation-schemas/email-sending-validation-schema.ts:12; backend/lib/email/save-email-sending.ts:23 **Found:** 2026-10-27 by /audit independent current (scope: 7abbf56..3ae2eca; lenses: quality, security, performance, tests) **Why it matters:** Before 25a a saved sender only worked with the business's own Resend key, so Resend itself kept each business to the domains in its own account. Now every business sends through the agency's key, which the spec wants set to "All domains", and rule 1 trusts the saved sender as is: the card's PUT (any role with `organization: ["update"]`) accepts any well-formed address, and `resolveBusinessSender` returns it with no check that its domain belongs to this business. So the owner of business A can save `bookings@<business B's domain>` or `anything@booking-crm.com`, then book on A's own public page with any recipient address, and the agency key sends a DKIM-signed email from B's domain (or the platform's), with A's business name, service names and details in it. The same unchecked domain also becomes A's `ownDomain`, so A's work emails may be saved at B's domain. The website (rule 2) is set only by the platform admin, so the hole is the owner-editable saved sender. It is a cross-tenant trust break today and opens to anyone with self-serve signup (item 25). **Suggested fix:** Honour a saved sender only when its domain equals the business's website domain (admin-set) and is not `booking-crm.com`; otherwise ignore it in the resolver and refuse it on save with a field message. Or make the sender field platform-admin only. Add a test that a saved sender at another domain is not used. **Resolution:** fixed 2026-10-27 on feature/25a: the resolver now uses only the business's website domain, and only once it shows Resend's signing record: a saved sender is honoured only at that domain, else bookings@ that domain, else booking-crm.com (resolve-business-sender.ts, website-domain.ts). Saving the card refuses a sender not at the website's domain, or any sender while there is no website, with sender_not_own_domain under the field (save-email-sending.ts, email-sending-routes.ts). The work-email domain follows the same rule. Tests: resolve-business-sender.test.ts (another domain never used), email-sending-routes.test.ts (refused under its field, nothing changes; no website, no sender), settings-routes.test.ts (work emails at the website's domain). Closed 2026-10-27 by /audit independent current (fresh subagent, 7abbf56..6e76d60): re-examined resolve-business-sender.ts:26-35, website-domain.ts, save-email-sending.ts:33-45 and the route. The sending domain now comes only from `organization.website`, which only POST /admin/clients (platform admin) and the client-setup script write; it is not a Better Auth `additionalFields` entry, so the organization update route cannot set it. A saved sender is used only when it ends in `@<website domain>` and that domain shows the signing record, and the card's PUT refuses any other sender (email-sending-routes.test.ts, 422 `sender_not_own_domain`, row unchanged). The original cross-tenant path is gone. The guard's reliance on the website staying admin-only, and `booking-crm.com` not being excluded as the website domain, are tracked separately as F-540.

Independent review

Status: passed **Target commit:** 6e76d6030b208ecaaa7cbfce114ad4c448e591a1 **Base commit:** 7abbf56d796fc9fe02f4902afe85d99b9376ab97 **Base ref:** main **Spec hash:** ca4278560a18fceda9aaa9d109f5588e4bffdf7027c7e837308adbe5bae1b66a **Prepared by:** claude **Builder model:** claude-opus-5-5 **Requested reviewer:** claude **Requested model:** claude-opus-5-5 **Requested execution:** automatic **Requested at:** 2026-10-27T14:56:09Z **Workflow:** regular **Check required:** no **Reviewer adapter:** claude **Reviewer model:** claude-opus-5-5 **Reviewer context:** fresh subagent **Actual execution:** automatic **Reviewed at:** 2026-10-27T15:04:01Z **Scope:** current **Lenses:** quality, security, performance, tests **Verdict:** passed **Check result:** not-required

Commands

- `npm run test --workspace=backend` : pass (96 files, 1097 tests)
- `npm run test --workspace=@scheduleads-app/shared` : pass (32 files, 210 tests)
- `npm run build --workspace=backend` : pass
- `npm run build --workspace=frontend` : pass
- `npm run lint --workspace=frontend` : pass

Evidence

- Preflight: HEAD equals the target, `git merge-base main HEAD` equals the base, the spec's SHA-256 matches, and only `blueprint/context/review.md` differed from the target before this pass.
- Tenant scope: the sending domain comes only from `organization.website` (resolve-business-sender.ts:26), which only POST /admin/clients and the client-setup script write; it is not a Better Auth organization `additionalFields` entry, so the organization update route cannot set it. The card's routes take the business from the session; the owner query in find-business-email-details.ts is scoped to the organization.
- No business can send from another business's domain or from booking-crm.com by its own choice: a saved sender is used only at `@<website domain>` with the signing record (resolver), and PUT /email-sending refuses any other with 422 `sender_not_own_domain` (email-sending-routes.test.ts). Latent hardening recorded as F-540.
- No key or address in a log line or answer: send-email.ts logs kind and idempotency key only, SendEmailError carries Resend's name and status only, logNothingSent carries ids only; the card's answer holds the business's own addresses and its owner's login email, which members can already list. Tests fake the agency key and a global fetch guard in vitest.setup.ts blocks any non-local request.
- Fallback idempotency: the 403 resend uses `<key>/agency` with the same payload, so a retry dedupes at Resend; the test at send-booking-emails.test.ts:406-439 checks both keys and the timeline.
- DNS check: `resend._domainkey.<domain>` TXT with a non-empty `p=` , any failure counted as not set up, cached one hour (has-resend-signing-record.ts, its tests). It cannot tell whose Resend account published the record, which reopens F-532.

Findings

- F-531 [P1] closed: the owner-editable sender can no longer pick the domain; verified in code and tests.
- F-532 [P2] reopened (open): a domain verified in the business's own Resend account passes the DNS check, so the card says "from your domain" while every email 403s and goes from booking-crm.com.
- F-533 [P3] open, unchanged: `.env.example` still describes per-business Resend accounts.
- F-534 [P3] open, unchanged: fallback log names no business and says "sent" before the resend.
- F-535 [P3] open, unchanged: DNS lookup without a limit, inside save-resource's transaction.
- F-536 [P3] open, partly addressed: website-domain work email now tested; text-reply 403 fallback and a real before-Resend failure still untested.
- F-537 [P3] open, new: spec, AGENTS.md and comments still describe the pre-repair sender rule.
- F-538 [P3] open, new: eight dead key-era Spanish strings; work-email refusal points the owner at a card that cannot fix it.
- F-539 [P3] open, new: admin client setup accepts a sender at any domain, which the emails silently ignore.
- F-540 [P3] open, new: the guard rests on the website staying admin-only, and booking-crm.com is not excluded as an own domain.

Remaining risk

- Check was not required and not run; the email card at http://localhost:3400 was not seen in a browser.
- Resend's real answers (403 for an unverified domain, idempotency behaviour after a refused key) are faked in tests and not verified against the live API.
- The agency key's domain scope in Resend is the spec's open question, checked by Frank before release, not in code.
- On a fallback the attached invite's ORGANIZER still names the own-domain sender while the email comes from booking-crm.com; calendar clients were not tested against that mismatch (unverified).